

工程承攬業銷售與收款循環治理型 SOP 架構研究

治理定位與研究結論

以台灣上市櫃公司的治理語境來看，這個 pilot case 最合適的產出，不是把文件拆成大量彼此分離的 ISO 式程序書，而是一份**董事會可核准、內稽可查核、資訊可實作、未來可複製**的 Level 2 + Level 3 混合治理文件。原因很直接：公開發行公司內部控制制度必須以書面訂定並經董事會通過；設有審計委員會者，訂定或修正內控制度應先經審計委員會同意，再提董事會決議；同時，內控制度必須涵蓋全部營運活動、產業特性、科技環境與資訊系統控制。上市上櫃公司治理實務守則又要求董事會與管理階層至少每年檢討各部門自評結果，並按季檢核稽核單位的稽核報告。這代表文件設計若只追求流程說明、卻沒有核准路徑、控制點、證據鏈與改善閉環，就不是真正可治理的文件。¹

工程承攬業的銷售與收款循環，天然比一般買賣業更長，也更依賴契約條件。公開發行公司內控準則已明定，銷售及收款循環至少應涵蓋訂單處理、授信管理、提供勞務、開立發票、開出帳單、記錄收入及應收帳款、處理折讓退回、客訴與現金收入等作業；而在工程承攬場景，還會延伸出契約變更、估驗、分階段請款、保留款、部分驗收、正式驗收與尾款釋放。公共工程委員會的契約要項與工程契約範本也要求，契約中應明定價金給付條件、應提文件、給付方式與期限；依履約進度給付者，應明定各次給付對應的履約進度與進度報告；工程估驗又通常伴隨估驗明細、審核、付款期限與保留款機制。對民間工程而言，這些不一定逐條強制，但它們確實是台灣工程流程治理最成熟、最可借鏡的在地控制模型。²

因此，這份 SOP 架構的正確起點，不是 AI Audit，也不是 Agent governance，而是先把 contract-to-cash 做成**可重建的資料鏈**：合約版本、變更版本、估驗證據、請款版本、ERP 應收分帳、收款沖銷、驗收結案、電子簽核與 log 都必須能追溯。公開發行公司使用電腦化資訊系統時，法規要求至少要有部門權責劃分、系統開發與程式修改控制、程式及資料存取控制、資料輸出入控制、資料處理控制、系統復原與資安檢查等控制；而電子文件與電子簽章在符合法律要求時，不得僅因為電子形式而否認法律效力，且電子保存可併同保留簽署歷程、日期、時間等真偽驗證資訊。這正是 Computer Audit 必須先落地的基礎。³

法規與實務基礎

台灣上市櫃公司的內控邏輯，與 ISO 9001 的文件邏輯並不相同。公開發行公司內控準則把內控制度定義為經理人設計、董事會通過、由董事會、經理人及其他員工執行的管理過程，其目的在合理確保營運之效果與效率、報導之可靠性/及時性/透明性/合規，以及法令遵循；同時要求控制環境、風險評估、控制作業、資訊與溝通、監督作業等組成要素。相對地，ISO 9001 是品質管理系統標準，重點在流程方法、風險思維、documented information、監測衡量與持續改善。換言之，本案可以借用 ISO 的文件紀律，但不能讓 ISO 的拆分習慣壓過台灣上市櫃內控、董事會治理與內部稽核的需要。⁴

對 pilot case 更關鍵的是，公開發行公司年度稽核計畫至少要包含法令遵循、重大財務業務控制、對子公司監督管理、董事會議事運作管理、財務報表編製流程管理、資通安全檢查，以及**銷售及收款循環**等重要營運循環；稽核報告、工作底稿與相關資料至少保存五年。上市上櫃公司治理實務守則則進一步要求董事會與管理階層每年檢討自評結果，並按季檢核稽核報告；發現內控缺失與異常事項後，應持續追蹤改善。這表示本案文件不能只是「給現場看懂」，還必須天然對接年度稽核、自評、季度缺失追蹤與董事會監督。⁵

工程承攬的在地流程控制，則可從政府採購與公共工程契約中提煉出幾個高價值參考。首先，契約價金給付應在契約中明定：給付前應完成的履約事項、應提文件、給付金額、給付方式、給付期限；若依履約進度給付，應明定每次給付對應的履約進度及進度報告。其次，工程契約實務普遍存在定期估驗或分階段付款，且付款前須有估驗或階段完成證明；公共工程法第 73-1 條並要求工程採購在廠商提出估驗或階段完成證明文件後，原則

上於十五個工作日內完成審核，再於收訖請款單據後十五個工作日內付款。再者，工程估驗常有保留款；工程契約範本長期採用估驗款逐期扣留保留款，並在初驗／驗收與保固條件成熟後分段返還。這些規範雖主要來自公共工程，但非常適合拿來設計民間工程承攬的 SOP 骨架，尤其是估驗、請款、收款與驗收的切分。 6

電子化與留存方面，電子簽章法第 4、5、8 條已提供清楚的法制地基：電子文件及電子簽章在功能上等同於實體文件及簽章；依法令規定應書面或簽名蓋章者，符合條件時得以電子文件與電子簽章為之；依法令規定應書面保存者，只要內容可完整呈現並可於日後取出查驗，就可以電子文件保存，且得併同保存發文地、收文地、網路位址、簽署歷程、日期、時間等驗證資訊。另就底線保存年限而言，商業會計法要求會計憑證至少保存五年，會計帳簿與財務報表至少保存十年；內控稽核底稿相關資料至少保存五年。因此，本案不應只談「表單電子化」，而應明確規範**何種文件、何種 log、保留多久、用什麼索引鍵可回查**。 7

建議的整體文件架構

我建議採用「一份主文件+六份附件」的方式，而不是把程序、SOP、工作說明書、系統說明、表單說明全部拆散。主文件負責治理骨架，附件負責持續維護與系統化細節。這樣既能符合內控要求的書面化與董事會可監督性，也能避免每次 ERP 欄位或 Workflow 核簽路徑調整時，就動到整份董事會層級文件。這種做法，是把 Level 2 與 Level 3 混成一個「治理主體」，再把高變動細節放在受控附件中。其核准與版控邏輯，係依公開發行公司內控準則的董事會書面化要求、上市櫃治理守則的董事會/管理階層監督要求，以及電子文件可保存、可驗證的法制基礎所設計。 8

文件	建議定位	建議核准與版控	主要內容
主文件《工程承攬業銷售與收款循環治理作業辦法》	Level 2 + Level 3 混合主體	納入內控制度體系；核心控制原則由審計委員會/董事會路徑承接	目的、範圍、流程、權責、KCP、系統控制、表單關聯、監督與改善
附件 A《流程圖與 RACI 矩陣》	使用者導向附件	管理階層受控版次	跨部門泳道、角色、交接點、替代機制
附件 B《KCP 與 Computer Audit 控制矩陣》	稽核/資訊雙語附件	稽核主管、CIO/資訊主管、財會主管共同維護	控制目的、風險、測試方式、證據、例外處理
附件 C《ERP / Workflow / Audit Trail 欄位規格》	系統落地附件	CIO/資訊主管受控版次	主檔、交易檔、狀態碼、強制欄位、log、報表
附件 D《表單與佐證文件目錄》	文件治理附件	文件管理權責單位維護	契約、變更、估驗、請款、驗收、收款、爭議等表單及其關聯
附件 E《異常、逾期與爭議處理矩陣》	營運風險附件	財會、法務、工程單位共同維護	異常碼、責任單位、升級時點、處置 SLA
附件 F《版本、留存與封存規範》	長期維運附件	文件管理與資訊共同維護	保存年限、封存、調閱、銷毀、電子證據留存規則

這個架構的要害，在於把「**主文件是治理準則，附件是維運介面**」這件事講清楚。主文件要少變、穩定、可被董事會與內稽引用；附件要能快速更新，尤其是 RACI、ERP 欄位字典、Workflow 路由、異常碼與報表欄位。若把所有細節都塞進董事會版文件，文件會很快失控；若反過來只做操作手冊、不做治理主文件，則稽核與董事會很難有效監督。 1

建議的 Level 2 與 Level 3 混合目錄

下列目錄刻意把「程序、權責、控制點、系統控制、證據與表單」放在同一個文件骨架中，而不是拆成多層獨立文件。這樣做的理由，是公開發行公司內控準則對銷售及收款循環本來就採端對端定義，且資訊系統控制與營運流程控制必須在同一個治理視野下被設計；ISO 9001 則提供文件紀律與持續改善邏輯，但不要求必然碎片化。

章節	章節目的
文件基本資訊與控管方式	定義文件性質、版次、核准層級、文件擁有人、關聯附件
目的、適用範圍與治理目標	明確界定本文件是內控/治理文件，不只是操作說明
流程定義與角色權責	定義業務、工程、財會、法務、資訊、內稽的責任界面
合約審查與案件建檔	將契約條件、授信/業主風險、主檔建置與案件啟動連成一體
契約變更與補充約定管理	管理追加減、暫估、工期調整、價金調整與版本控管
工程估驗管理	管理由工程進度證據到估驗明細、核認、送審的完整鏈條
請款與發票管理	管理請款條件、金額校驗、稅務文件、帳單與發票一致性
應收帳款與保留款管理	管理正常應收、保留款、尾款、爭議款、扣款與對帳
收款、沖帳與差異處理	管理入帳、銀行對接、自動配對、人工例外與沖銷核准
驗收、結案與尾款釋放	管理部分驗收、正式驗收、結案證明、尾款與保留款釋放
異常、逾期與爭議處理	管理客訴、施工爭議、請款退件、逾期款、法務升級
ERP、Workflow、電子簽核與 Audit Trail	管理權限、流程狀態、log、欄位字典、強制附件與版本追溯
文件、表單與留存規範	明確規定每一節的輸入、輸出、附件與保存方式
監督指標、自評、內稽與改善追蹤	對接年度自評、年度內稽、季度追蹤與管理報表

如果只做一份 pilot 文件，我會把「ERP、Workflow、電子簽核與 Audit Trail」直接寫進主文件，而不是另立一本資訊手冊。原因是公開發行公司在電腦化資訊系統上的控制，依法本來就是內控制度的一部分，不是資訊部門的獨立世界；且年度稽核計畫也明確要求納入資通安全檢查與銷售及收款循環。對上市櫃公司而言，把系統控制留在文件外，等於主動切斷可稽核性。

章節目的與控制矩陣

下列 KCP 並不是照抄法規條文，而是依公開發行公司內控對銷售及收款循環、電腦化資訊系統控制、年度稽核必查項目，以及工程估驗、驗收、付款、契約變更與電子證據保存規則，整理成一套可落地的 Computer Audit 切入矩陣。公共工程相關條文在此是工程承攬治理參考模型，不是對全部民間工程一概主張強制適用。

前端建檔與契約管理

KCP	控制目的	Computer Audit 切入點	ERP / Workflow 關聯	關聯文件與表單
KCP-A 合約條件審查	在案件啟動前，確認價金公式、請款里程碑、驗收條件、保留款、稅務條款、變更條款、違約責任與收款條件已完成跨部門審查	Workflow 必填欄位、核准層級、簽核時間戳、版本 ID；未完成審查不得轉正式案件	合約主檔、客戶主檔、專案主檔建立前置	合約審查表、授信/業主風險評估、案件啟動申請
KCP-B 主檔建置與主檔異動	確保一案一碼、一客戶一主檔、統一稅籍/銀行/收款資訊，不讓相同案件以多碼分散	主檔異動 maker-checker、異動 log、重複主檔警示	客戶主檔、專案主檔、收款條件主檔	主檔建置申請、主檔異動申請
KCP-C 契約變更與追加減	變更未核准前不得直接計入正式請款；若須先行施作，應有受控的暫估機制與版本標記	變更單號流水、前後版差異留痕、未核准變更不得放行估驗/請款，除非啟用暫估旗標	變更單、預算差異、價金調整、工期調整	變更申請單、追加減明細、補充協議
KCP-D 權限分離	將估驗核認、請款編製、應收入帳、收款沖帳、折讓/沖銷、權限維護分離	RBAC、核准額度、特權帳號清冊、定期權限複核	角色矩陣、Workflow 路由、ERP 權限模板	權限申請單、權限定期複核表

估驗、請款與應收

KCP	控制目的	Computer Audit 切入點	ERP / Workflow 關聯	關聯文件與表單
KCP-E 工程估驗證據與數量核認	估驗必須有可驗證的進度與數量依據，不可僅憑口頭或單一人員判斷	強制附件、估驗期間鎖定、估驗後修改 log、數量容忍度檢核	估驗期間、工程進度、對應契約版次與變更版次	估驗明細單、工程進度報告、現場簽認/監造確認
KCP-F 請款條件校驗	僅在契約條件、變更條件與估驗條件都成立時，才可進入請款	系統自動比對契約條件、估驗金額、保留款比率、稅額、既開立帳單與既請款餘額	請款申請、帳單、發票開立請求	請款申請單、請款檢核表、發票開立申請
KCP-G 應收與保留款分帳	把正常應收、保留款、尾款、暫估款、爭議款拆開管理，避免混帳	文件類型限制、手工分錄受控、科目與交易類型映射、異常分錄報表	AR 類型、專案別帳齡、保留款台帳	應收建檔清單、保留款台帳、尾款追蹤表
KCP-H 帳單、發票與 ERP 一致性	確保對外帳單、稅務文件與 ERP 金額、期間、專案別一致	單號唯一性、跨系統一致性校驗、作廢/折讓 log	帳單號、發票號、請款號、專案號關聯	帳單、發票、折讓單、對帳單

收款、驗收與結案

KCP	控制目的	Computer Audit 切入點	ERP / Workflow 關聯	關聯文件與表單
KCP-I 收款與沖帳	確保入帳、配對、差異處理與沖銷獨立運作，不讓請款端自行消滅應收	銀行匯入、自動配對規則、未配對例外佇列、沖銷核准 log	現金收款、沖帳、折讓、扣款、差異碼	收款通知、沖帳申請、折讓/扣款核准單
KCP-J 驗收、部分驗收與尾款釋放	將部分驗收、正式驗收、尾款與保留款釋放連動管理	驗收狀態碼、放行條件、驗收後十五日內文件產出提醒、未驗收阻斷尾款釋放	驗收里程碑、結案狀態、保留款釋放日期	驗收紀錄、結算/結案證明、保留款釋放申請
KCP-K 逾期、爭議與異常	對逾期帳款、請款退件、扣款爭議、品質爭議建立標準異常碼與升級規則	帳齡儀表板、逾期預警、異常碼分析、爭議凍結邏輯	帳齡、催收紀錄、爭議狀態、法務升級	催收紀錄、異常處理單、爭議協商紀錄
KCP-L 電子簽核、版本與留存	任何關鍵交易都必須能回查誰、何時、依哪一版文件核准	文件版本控管、簽署歷程、日期時間、附件索引、封存與刪除 log	DMS 文件 ID、Workflow 簽核歷程、ERP 附件鍵值	版次紀錄表、封存/調閱/銷毀申請

這個矩陣裡最重要的設計，不是多加幾個簽核節點，而是把**結構化資料與證據文件**一起治理。工程承攬最常見的失控點，往往不是沒有文件，而是文件存在、但系統抓不到；或是 ERP 有帳、但找不到對應的合約版本與估驗證據；或是請款、收款、保留款混在同一個狀態欄位裡，之後既不能追蹤，也不能做 Computer Audit。法規要求的，其實不是「簽很多次」，而是合理確保交易經過適當核准、資訊可供規劃/執行/監督使用、缺失可被發現並改善。 12

導入與維運路徑

這個 pilot 若要真正可維運，導入順序應該是「**文件先定義、欄位再定義、控制再上系統、監督再做儀表板**」。先把主文件與附件 A/B/D 定稿，建立共通語言；再把附件 C 的欄位字典、狀態碼、關聯鍵、權限矩陣定義清楚；之後才由 ERP / Workflow 落地強制欄位、流程阻斷、例外報表與 log；最後再把附件 E/F 與監督指標接上月結、季追蹤、年度自評與年度內稽。這樣的順序，最符合上市櫃公司內控、年度稽核與季度追蹤的節奏。

5

在維運設計上，最少要固定五件事。第一，**唯一索引鍵**：專案代號、合約號、合約版本、變更單號、估驗期間、請款號、發票號、收款號必須能關聯。第二，**狀態碼分離**：估驗、請款、發票、應收、收款、驗收、保留款釋放不能共用一個模糊狀態。第三，**權限分離**：編製、覆核、核准、入帳、沖帳、權限維護不能集中。第四，**例外代碼化**：請款退件、扣款、爭議、逾期、暫估、保留、法務升級都要代碼化。第五，**附件與 log 必須可匯出給稽核**：否則再好的系統都不具 auditability。這些雖是實務設計建議，但其基礎正是內控準則對資訊與溝通、監督作業、電腦化資訊系統控制，以及電子文件可驗證保存的要求。 3

AI-assisted Governance 在這個架構裡可以有位置，但必須是**後設增強**，不是前置替代。當合約、變更、估驗、請款、應收、收款、驗收與電子證據都已經標準化之後，AI 最適合做的是文件完整性檢查、異常摘要、帳齡風險提醒、變更與請款不一致警示、以及缺失改善追蹤摘要；它不應先取代核准、記帳或判斷付款條件。對這個 pilot case 而言，真正的關鍵成品不是炫目的自動化，而是一套**董事會看得懂、內稽查得到、資訊做得出、單位願意維持**的治理文件與證據鏈。這個基礎一旦穩定，未來再延伸 AI，才不會把治理建立在沙上。

1 2 3 4 5 8 9 10 11 12 <https://law.moj.gov.tw/LawClass/LawAll.aspx?pcode=G0400045>
<https://law.moj.gov.tw/LawClass/LawAll.aspx?pcode=G0400045>

6 <https://www.pcc.gov.tw/content/index?eid=2867&type=C>
<https://www.pcc.gov.tw/content/index?eid=2867&type=C>

7 <https://law.moj.gov.tw/LawClass/LawSingle.aspx?flno=4&pcode=J0080037>
<https://law.moj.gov.tw/LawClass/LawSingle.aspx?flno=4&pcode=J0080037>